

Πανεπιστήμιο Δυτικής Αττικής
Σχολή Μηχανικών
Τμήμα Μηχανικών Πληροφορικής και Υπολογιστών

Ασφάλεια στην τεχνολογία της πληροφορίας

5η Εργασία

ΝΙΚΟΛΑΟΣ ΘΩΜΑΣ
ΑΜ: 21390068

ΑΘΗΝΑ

Περιεχόμενα

Δραστηριότητες 3

1. Ολοκλήρωση εγκατάστασης του OPNSense 25.1 3
2. Βασική Παραμετροποίηση 3
3. Δημιουργία VM και βασική εγκατάσταση Apache Web Server που να ακούει στην πόρτα 80 (http) 5
4. Πολιτική ασφαλείας 6
5. Προτεινόμενοι επιπλέον κανόνες και ρυθμίσεις για θωράκιση του οργανισμού 9
6. Δυνατότητες OPNsense για βελτίωση ασφάλειας, απόδοσης και monitoring 9

Θεωρητικές Ερωτήσεις 10

1. Πώς μπορούμε να δώσουμε πρόσβαση στο διαχειριστικό περιβάλλον του OPNsense από απομακρυσμένο δίκτυο με ασφάλεια; 10

2. Ποια είναι η βασική διαφορά ανάμεσα σε ένα Floating Rule και ένα LAN Rule στο OPNsense; 10

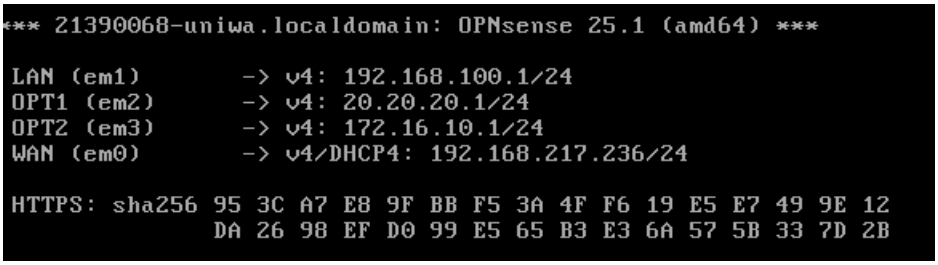
3. Έστω ότι θέλετε να κόψετε την πρόσβαση σε μια εξωτερική IP για όλους τους clients, ανεξαρτήτως interface. Ποιο είδος rule θα χρησιμοποιήσετε και γιατί; 10

4. Ένας χρήστης στο LAN δεν μπορεί να πλοηγηθεί στο internet, παρότι υπάρχει επιτρεπτικός κανόνας. Ποια βήματα ακολουθείτε για να εντοπίσετε το πρόβλημα; 10

Δραστηριότητες

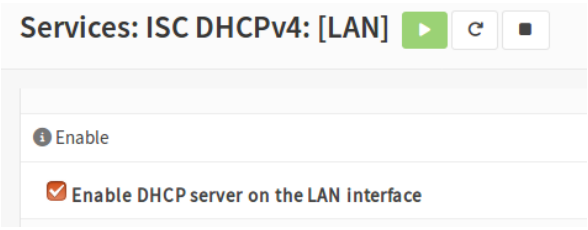
1. Ολοκλήρωση εγκατάστασης του OPNSense 25.1

Έχουμε κάνει 1. Assign interfaces και 2. Set interface IP addresses όπως φαίνεται από την παρακάτω εικόνα βάση του network που θέλουμε.



Εικόνα 1: Network OPNsense

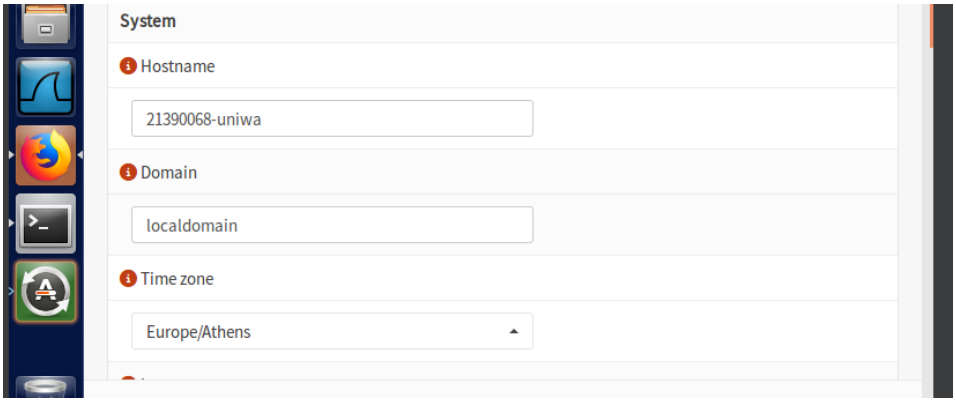
Επιπλέον έχουμε ενεργοποιήσει το DHCP για το LAN.



Εικόνα 2: DHCP Enabled

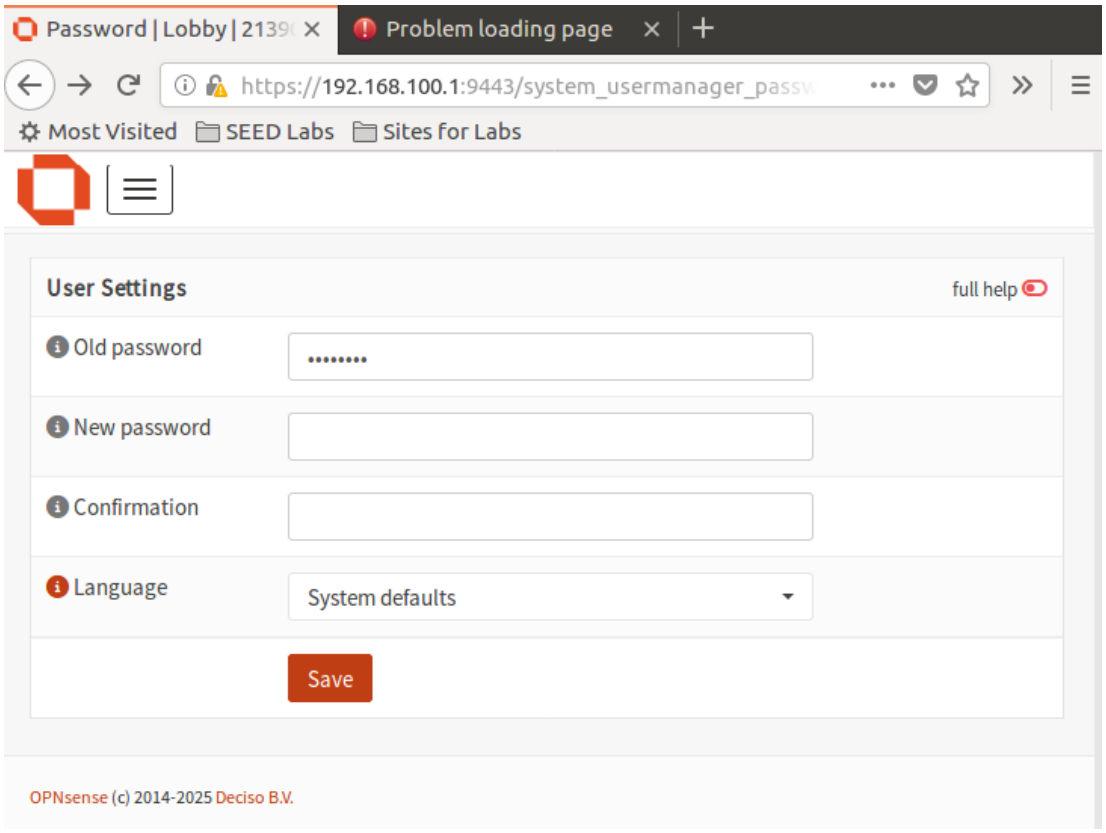
2. Βασική Παραμετροποίηση

Αλλαγή του ονόματος και της ώρας:



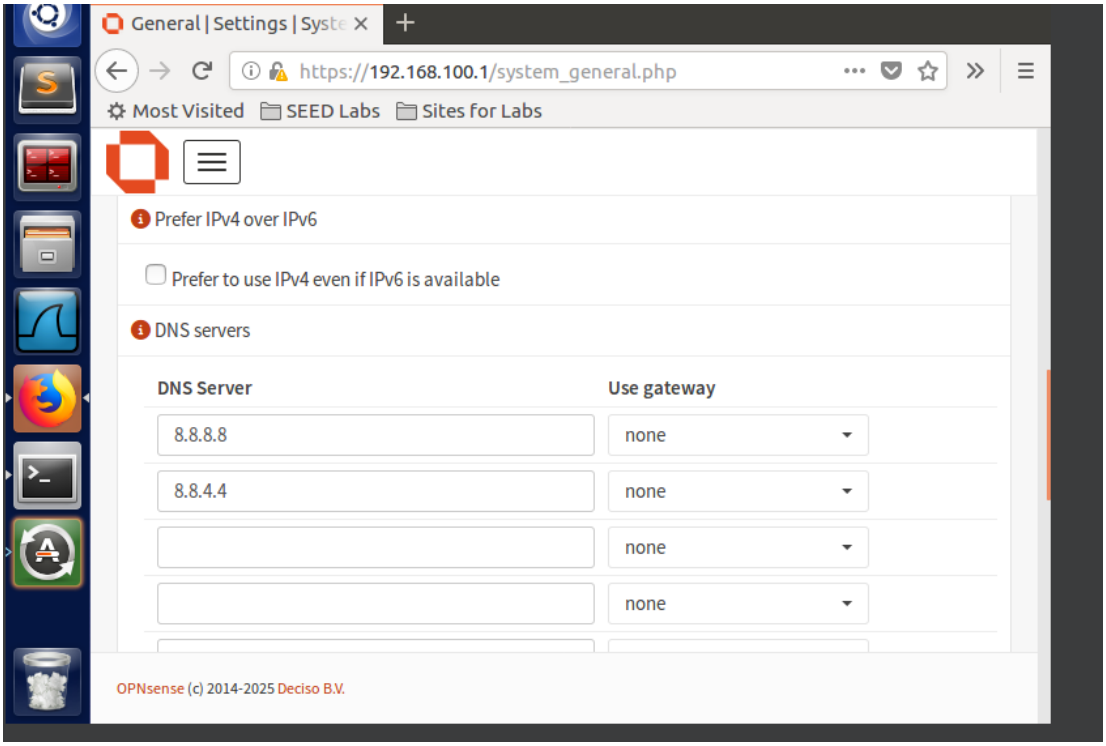
Εικόνα 3: OPNsense Interface

Αλλαγή του root κωδικού:



Εικόνα 4: Root Password

Προσθήκη των DNS:



Εικόνα 5: OPNsense DNS

3. Δημιουργία VM και βασική εγκατάσταση Apache Web Server που να ακούει στην πόρτα 80 (http)

```
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 10
0
    link/ether 08:00:27:1a:c1:72 brd ff:ff:ff:ff:ff:ff
    inet 172.16.10.10/24 brd 172.16.10.255 scope global enp0s3
       valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe1a:c172/64 scope link
       valid_lft forever preferred_lft forever
```

Εικόνα 6: WebServer IP

```
  GNU nano 7.2                  00-installer-config.yaml *
network:
  version: 2
  ethernets:
    enp0s3:
      dhcp4: no
      addresses: [172.16.10.10/24]
      gateway4: 172.16.10.1
      nameservers:
        addresses: [8.8.8.8, 8.8.4.4]

^G Help      ^O Write Out ^W Where Is  ^K Cut       ^T Execute   ^C Location
^X Exit      ^R Read File ^\ Replace   ^U Paste     ^J Justify   ^- Go To Line
```

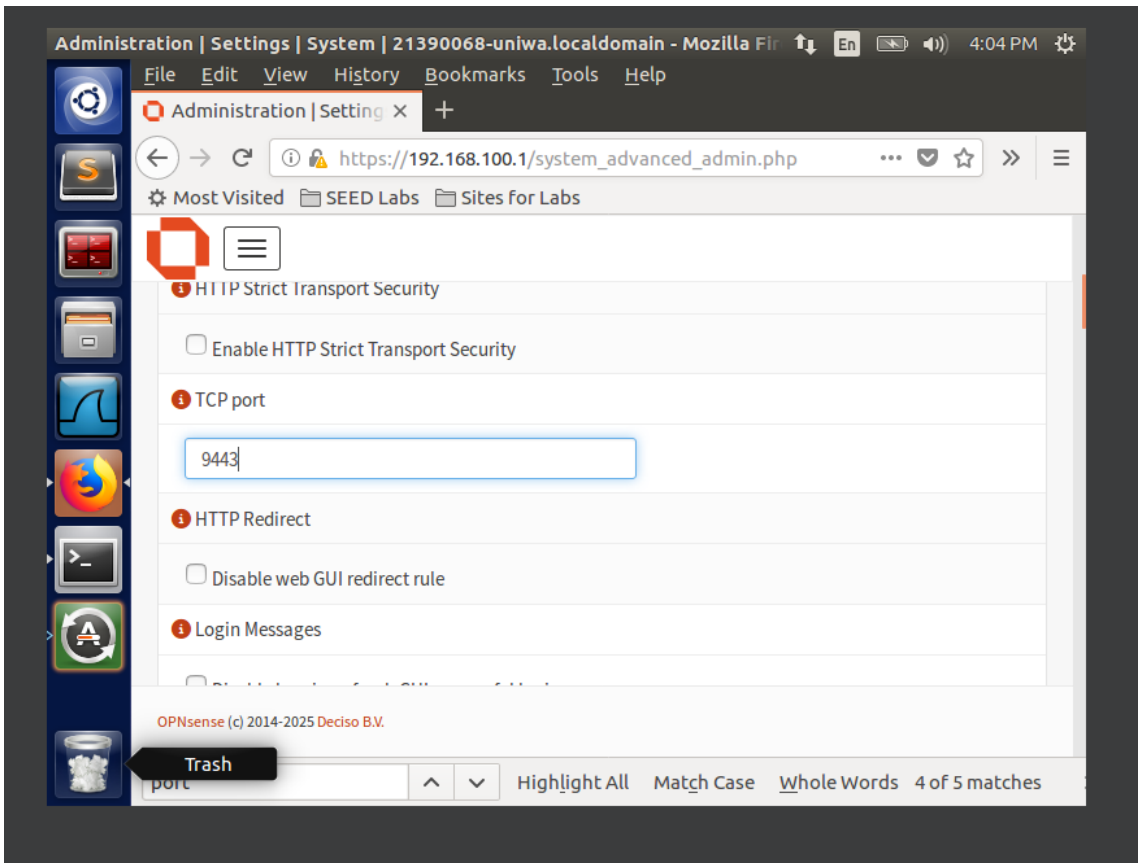
Εικόνα 7: Netplan – 00-installer-config.yaml

```
root@Ubuntu-WebServer:/etc/netplan# sudo apt install apache2 -y
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following additional packages will be installed:
  apache2-bin apache2-data apache2-utils libapr1t64 libaprutil1-dbd-sqlite3
  libaprutil1-ldap libaprutil1t64 liblua5.4-0 ssl-cert
Suggested packages:
  apache2-doc apache2-suexec-pristine | apache2-suexec-custom www-browser
The following NEW packages will be installed:
  apache2 apache2-bin apache2-data apache2-utils libapr1t64
  libaprutil1-dbd-sqlite3 libaprutil1-ldap libaprutil1t64 liblua5.4-0 ssl-cert
0 upgraded, 10 newly installed, 0 to remove and 0 not upgraded.
Need to get 2,084 kB of archives.
After this operation, 8,094 kB of additional disk space will be used.
Ign:1 http://archive.ubuntu.com/ubuntu noble-updates/main amd64 libapr1t64 amd64
 1.7.2-3.1ubuntu0.1
Ign:2 http://archive.ubuntu.com/ubuntu noble/main amd64 libaprutil1t64 amd64 1.6
.3-1.1ubuntu7
Ign:3 http://archive.ubuntu.com/ubuntu noble/main amd64 libaprutil1-dbd-sqlite3
amd64 1.6.3-1.1ubuntu7
Ign:4 http://archive.ubuntu.com/ubuntu noble/main amd64 libaprutil1-ldap amd64 1
.6.3-1.1ubuntu7
0% [Connecting to archive.ubuntu.com]_
```

Εικόνα 8: Apache2 Installation

4. Πολιτική ασφαλείας

Αλλαγή πόρτας από 443 σε 9443



Εικόνα 9: Port change

Τα rules για τα υπόλοιπα που ζητούνται έχουν δημιουργηθεί και φαίνται από το αρχείο xml. Μερικά από τα rules τα υπόλοιπα στο αρχείο xml:

```
 <filter>
  <rule uuid="ab22e25c-6094-45fd-9768-
b6ddacb7d61f">
    <type>pass</type>
    <associated-rule-
id>nat_68495ded2f26b7.15012947</associated-
rule-id>
    <source>
     <any>1</any>
    </source>
    <interface>wan</interface>
    <statetype>keep state</statetype>
    <protocol>tcp</protocol>
    <ipprotocol>inet</ipprotocol>
    <destination>
     <address>172.16.10.10</address>
     <port>80</port>
    </destination>
    <descr/>
    <category/>
    <created>
     <username>root@192.168.100.10</username>
     <time>1749638637.1939</time>
     <description>/firewall_nat_edit.php made
changes</description>
    </created>
  </rule>
```

```
<rule uuid="5d50ac90-bf6d-414b-b00d-
a34172a9524f">
    <type>pass</type>
    <interface>wan</interface>
    <ipprotocol>inet</ipprotocol>
    <statetype>keep state</statetype>
    <direction>in</direction>
    <quick>1</quick>
    <source>
     <any>1</any>
    </source>
    <destination>
     <network>wanip</network>
    </destination>
    <updated>
     <username>root@192.168.100.10</username>
     <time>1749640339.5314</time>
     <description>/firewall_rules_edit.php made
changes</description>
    </updated>
    <created>
     <username>root@192.168.100.10</username>
     <time>1749640339.5314</time>
     <description>/firewall_rules_edit.php made
changes</description>
    </created>
  </rule>
```

```
  <rule uuid="3b16a10d-a863-4567-81d3-4a4d4d247489">
    <type>pass</type>
    <interface>lan</interface>
    <ipprotocol>inet</ipprotocol>
    <statetype>keep state</statetype>
    <direction>in</direction>
    <quick>1</quick>
    <source>
     <network>lan</network>
    </source>
    <destination>
     <any>1</any>
    </destination>
    <updated>
     <username>root@192.168.100.10</username>
     <time>1749644881.0374</time>
     <description>/firewall_rules_edit.php made changes</description>
    </updated>
    <created>
     <username>root@192.168.100.10</username>
     <time>1749644881.0374</time>
     <description>/firewall_rules_edit.php made changes</description>
    </created>
  </rule>
```

```
  <rule uuid="45f29909-0299-481c-ab72-fdd608b35a20">
    <type>pass</type>
    <interface>lan</interface>
    <ipprotocol>inet</ipprotocol>
    <statetype>keep state</statetype>
    <direction>in</direction>
    <quick>1</quick>
    <source>
     <address>192.168.100.0/24</address>
    </source>
    <destination>
     <any>1</any>
    </destination>
    <updated>
     <username>root@192.168.100.10</username>
     <time>1749647607.5674</time>
     <description>/firewall_rules_edit.php made changes</description>
    </updated>
    <created>
     <username>root@192.168.100.10</username>
     <time>1749647607.5674</time>
     <description>/firewall_rules_edit.php made changes</description>
    </created>
  </rule>
```

5. Προτεινόμενοι επιπλέον κανόνες και ρυθμίσεις για θωράκιση του οργανισμού

1. **Ενεργοποίηση Intrusion Detection System (IDS) / Intrusion Prevention System (IPS):**
   Χρήση του Suricata ή Snort module του OPNsense για ανίχνευση και πρόληψη επιθέσεων δικτύου σε πραγματικό χρόνο.
2. **Χρήση VPN για ασφαλή απομακρυσμένη πρόσβαση:**
   Ρύθμιση OpenVPN ή IPsec VPN για ασφαλή σύνδεση των χρηστών στο δίκτυο του οργανισμού, αποτρέποντας υποκλοπές.
3. **Firewall rules με πιο αυστηρούς περιορισμούς:**
   a. Χρήση whitelist αντί για blacklist όπου είναι δυνατόν.
   b. Περιορισμός πρόσβασης στα απαραίτητα ports και IPs.
   c. Ενεργοποίηση κανόνων logging για παρακολούθηση ύποπτης δραστηριότητας.
4. **Rate Limiting και GeoIP blocking:**
   Περιορισμός αιτημάτων από συγκεκριμένες IP ή περιοχές (γεωγραφικά), ώστε να μειωθούν οι πιθανότητες επιθέσεων.
5. **Two-factor authentication (2FA) για πρόσβαση στο Web GUI:**
   Ενεργοποίηση 2FA για πρόσθετη ασφάλεια στη διαχείριση του OPNsense.
6. **Automatic updates:**
   Ενημέρωση του firewall και των modules σε τακτική βάση για την αποφυγή ευπαθειών.

6. Δυνατότητες OPNsense για βελτίωση ασφάλειας, απόδοσης και monitoring

- **Suricata IDS/IPS:** Ανίχνευση και αποκλεισμός επιθέσεων δικτύου με υποστήριξη πολλαπλών κανόνων και υπογραφών.
- **Proxy server με content filtering (Squid + SquidGuard):** Φιλτράρισμα ιστοσελίδων και caching για αύξηση ταχύτητας και ασφάλειας.
- **Traffic shaping και QoS:** Διαχείριση και προτεραιοποίηση της κυκλοφορίας για βελτίωση της απόδοσης του δικτύου.
- **NetFlow και Insight:** Παρακολούθηση κυκλοφορίας και ανάλυση δικτύου για εύρεση προβλημάτων και ασυνήθιστων μοτίβων.
- **Dynamic DNS:** Ενημέρωση δυναμικών διευθύνσεων IP για απομακρυσμένη πρόσβαση.
- **High Availability (CARP):** Ρύθμιση συστημάτων firewall σε κατάσταση εφεδρείας για αδιάλειπτη λειτουργία.
- **Package Manager:** Εγκατάσταση πρόσθετων πακέτων όπως OpenVPN, pfBlockerNG (για blocking κακόβουλων IPs και domains), και άλλα.
- **Logging και Reporting:** Πλήρης καταγραφή συμβάντων με δυνατότητα αποστολής ειδοποιήσεων email ή syslog σε κεντρικούς servers.

Θεωρητικές Ερωτήσεις

1. Πώς μπορούμε να δώσουμε πρόσβαση στο διαχειριστικό περιβάλλον του OPNsense από απομακρυσμένο δίκτυο με ασφάλεια;

Η ασφαλής πρόσβαση στο διαχειριστικό περιβάλλον του OPNsense από απομακρυσμένο δίκτυο μπορεί να επιτευχθεί μέσω **VPN (Virtual Private Network)**. Συγκεκριμένα, δημιουργούμε έναν OpenVPN ή IPsec VPN server στο OPNsense και οι απομακρυσμένοι χρήστες συνδέονται μέσω κρυπτογραφημένου καναλιού.

Αιτιολόγηση:

- Το VPN προσφέρει κρυπτογράφηση των δεδομένων, εξασφαλίζοντας ότι η διαχείριση δεν εκτίθεται ανοιχτά στο διαδίκτυο.
- Με αυτόν τον τρόπο, το διαχειριστικό interface δεν είναι διαθέσιμο σε όλο το διαδίκτυο, αλλά μόνο σε χρήστες που έχουν σωστά διαπιστευτήρια VPN.
- Εναλλακτικά, αν δεν χρησιμοποιείται VPN, ο περιορισμός πρόσβασης μόνο σε συγκεκριμένες IP (whitelist) και η χρήση 2FA βοηθούν στην αύξηση της ασφάλειας, αλλά το VPN παραμένει η πιο ασφαλής μέθοδος.

2. Ποια είναι η βασική διαφορά ανάμεσα σε ένα Floating Rule και ένα LAN Rule στο OPNsense;

- **LAN Rule:** Εφαρμόζεται μόνο στο interface LAN και επηρεάζει την κίνηση που περνάει από και προς το LAN. Είναι συγκεκριμένο και τοπικό.
- **Floating Rule:** Είναι κανόνας που μπορεί να εφαρμοστεί σε πολλά ή όλα τα interfaces ταυτόχρονα, και μπορεί να ρυθμιστεί ώστε να εφαρμόζεται είτε σε εισερχόμενη είτε σε εξερχόμενη κίνηση ή και στα δύο. Προσφέρει μεγαλύτερη ευελιξία στη διαχείριση κανόνων, π.χ. για κεντρικό blocking ανεξαρτήτως interface.

3. Έστω ότι θέλετε να κόψετε την πρόσβαση σε μια εξωτερική IP για όλους τους clients, ανεξαρτήτως interface. Ποιο είδος rule θα χρησιμοποιήσετε και γιατί;

Θα χρησιμοποιήσουμε **Floating Rule** με στόχο να μπλοκάρουμε την κίνηση προς την συγκεκριμένη IP ανεξαρτήτως από ποιο interface προέρχεται.
Αιτιολόγηση:

- Επειδή το Floating Rule εφαρμόζεται σε όλα τα interfaces ή σε συγκεκριμένα που θα ορίσουμε, είναι ιδανικό για παγκόσμιους κανόνες όπως blocking συγκεκριμένων IPs ανεξαρτήτως τοποθεσίας των clients.

4. Ένας χρήστης στο LAN δεν μπορεί να πλοηγηθεί στο internet, παρότι υπάρχει επιτρεπτικός κανόνας. Ποια βήματα ακολουθείτε για να εντοπίσετε το πρόβλημα;

1. **Επαλήθευση IP & Gateway:** Ελέγχω αν ο χρήστης έχει σωστή IP διεύθυνση και προεπιλεγμένη πύλη (gateway) στο δίκτυο LAN.
2. **Έλεγχος DNS:** Βεβαιώνομαι ότι ο χρήστης έχει σωστές ρυθμίσεις DNS για ανάλυση ονομάτων.
3. **Έλεγχος κανόνων firewall:** Ελέγχω αν υπάρχουν άλλα firewall rules που μπλοκάρουν την πρόσβαση (π.χ. κανόνες σε Floating ή WAN).

4. **Έλεγχος NAT:** Ελέγχω αν η διεύθυνση IP του LAN μεταφράζεται σωστά σε δημόσια IP μέσω NAT στο OPNsense.
5. **Ping & traceroute:** Κάνω ping σε εξωτερικές διευθύνσεις (π.χ. 8.8.8.8) και traceroute για να δω αν φτάνει η κίνηση στο διαδίκτυο.
6. **Logs:** Εξετάζω τα firewall logs για μπλοκαρισμένες συνδέσεις από την IP του χρήστη.
7. **Έλεγχος DHCP:** Αν ο χρήστης παίρνει IP μέσω DHCP, επιβεβαιώνω ότι το lease είναι σωστό και δεν υπάρχει σύγκρουση.